Security Incident Report: Web Server Compromise

1. Network Protocol Identified

The investigation identified HTTP (Hypertext Transfer Protocol) as the primary application-layer protocol used to access the affected websites. The tcpdump logs also show DNS queries and TCP connection establishment.

- **DNS:** DNS A-record queries resolved `yummyrecipesforme.com` to `203.0.113.22` and `greatrecipesforme.com` to `192.0.2.17` in the supplied sample log.
- **TCP:** The `[S]`, `[S.]`, and `[.]` flags indicate the TCP three-way handshake used to establish connections.
- **HTTP:** The log entries containing `HTTP: GET / HTTP/1.1` show requests for the root webpage of each domain. The `.http` service notation indicates HTTP traffic over port 80 in this capture.

These protocols supported domain resolution, connection establishment, and webpage requests during the investigation.

2. Incident Summary

Incident Overview

The cooking website `yummyrecipesforme.com` was compromised after an attacker gained access to its administrative account through a brute-force attack. According to the incident scenario, the administrator account still used its default password, and no controls were in place to adequately restrict repeated login attempts.

After gaining access to the administrative panel, the attacker modified the website's source code by injecting JavaScript that prompted visitors to download and run an executable file presented as a browser update. The attacker then changed the administrative account password, preventing the legitimate website owner from accessing the account.

Discovery and Impact

Several hours after the attack, customers contacted the website's helpdesk to report unexpected download prompts. They stated that their computers became slower after running the downloaded file and that their browsers redirected them to `greatrecipesforme.com`, a fraudulent website containing malware.

The website owner subsequently attempted to access the administrative panel but was unable to log in. The owner contacted the hosting provider, and the cybersecurity team investigated the incident in a sandbox environment.

Technical Findings

The tcpdump sample shows the following network activity:

1. A DNS A-record query resolved `yummyrecipesforme.com` to an IPv4 address.
2. A TCP connection was established with the website.
3. An HTTP GET request was sent for the website's root page.
4. After the suspicious download and execution sequence described in the scenario, a DNS query resolved `greatrecipesforme.com` to an IPv4 address.
5. A TCP connection was established with the second domain, followed by an HTTP GET request for its root page.

A senior analyst's examination of the website source code identified injected JavaScript that prompted visitors to download an executable file. Analysis of the downloaded file identified a script that redirected browsers from `yummyrecipesforme.com` to `greatrecipesforme.com`.

The supplied tcpdump excerpt supports the DNS resolution and HTTP/TCP connection activity. The malicious code injection, download behavior, and file-based redirection are supported by the scenario's source-code and file-analysis findings rather than by the displayed HTTP GET entries alone.

Evidence Sources

- Customer complaints submitted to the website's helpdesk.
- The website owner's report of being unable to access the administrative panel.
- The supplied tcpdump traffic log.
- Inspection of the compromised website's source code.
- Analysis of the downloaded executable file, as described in the incident scenario.

Incident Impact

The incident compromised the website's integrity and exposed visitors to a malicious download and redirection to a fraudulent website. Customers reported reduced computer performance after running the downloaded file. The attacker also disrupted the owner's administrative access by changing the account password.

3. Recommended Remediation

Implement login attempt rate limiting for the administrative account.

Configure the authentication system to restrict repeated failed login attempts within a defined time window. For example, progressively increasing the delay between failed attempts can make automated password guessing less effective. Temporary restrictions and monitoring should be configured carefully to reduce the risk of attackers deliberately locking out legitimate users.

This measure directly addresses the lack of controls that allowed the attacker to repeatedly guess the default administrator password. It should be combined with replacing default credentials with strong, unique passwords as part of the organization's broader security practices.

Conclusion

The incident demonstrates how weak administrative credentials and insufficient login protections can lead to website compromise, malicious code injection, and exposure of visitors to malware.

The investigation used network traffic observations alongside customer reports, website source-code inspection, and downloaded-file analysis to document the incident. Implementing login attempt rate limiting would help reduce the effectiveness of future brute-force attacks and strengthen administrative account security.

Scope and Limitations

This report documents a simulated security incident based on the provided course scenario and sample tcpdump log. The supplied log excerpt does not contain the administrative login attempts themselves, so the brute-force attack is attributed to the scenario's investigation findings rather than inferred directly from those packet entries.